

CISM Domain 3

Information Security Program Development

Comprehensive study notes compiled from the shared screenshots and discussed study topics

Focus: program development, governance, third-party risk, outsourcing, cloud computing, release management, compliance, current-state assessment, and continuous improvement.

Exam orientation: understand the sequence, ownership, risk-based decisions, and the difference between strategic governance and operational execution.

How to Use These Notes

These notes are organized around the topics visible in the supplied screenshots and the related Domain 3 study discussions. For the CISM exam, focus especially on the purpose of each activity, who owns it, what happens first, and how risk affects the decision.

A recurring CISM principle is: **align with business objectives, assess risk, define requirements, assign responsibility, implement controls, monitor effectiveness, and improve continuously.**

1. Information Security Program Development

An information security program is the coordinated set of governance structures, policies, processes, people, technologies, and metrics used to protect information and support business objectives.

The program should be:

- **Business-aligned:** supports business strategy, risk appetite, legal obligations, and operational priorities.
- **Risk-based:** controls are selected according to the likelihood and impact of threats, not merely because a control is popular or technically available.
- **Measurable:** objectives, metrics, reporting, and accountability are defined.
- **Integrated:** security is embedded into projects, procurement, development, operations, outsourcing, cloud use, and change management.
- **Continuously improved:** the program is reassessed as threats, technology, regulations, and business requirements change.

2. Assessing the Current State of the Information Security Program

The information security manager should assess the current state of the program at appropriate points and share the results with stakeholders. The assessment establishes where the organization is now, what is missing, and what should be improved.

The screenshots identify these assessment dimensions:

- **Program objectives:** Are security objectives clearly defined and aligned with business goals?
- **Program management:** Are governance, ownership, planning, budgeting, reporting, and accountability effective?
- **Technical security management:** Are security architectures, tools, engineering practices, vulnerability management, and technical safeguards effective?
- **Compliance requirements:** Are legal, regulatory, contractual, and internal requirements identified and met?
- **Security operations management:** Are monitoring, incident response, investigations, vulnerability handling, and operational processes working effectively?
- **Resource levels:** Are sufficient people, skills, funding, technology, and time available?

Typical inputs include audits, risk assessments, security reviews, incident trends, vulnerability scans, compliance reviews, stakeholder feedback, performance metrics, and changes in the business environment.

The output should identify strengths, weaknesses, gaps, risks, priorities, ownership, and a practical improvement roadmap.

3. Gap Analysis

Gap analysis compares the current state with the desired or required state. The gap may relate to policy, process, people, technology, architecture, skills, documentation, metrics, or compliance.

- Define the target state using business objectives, risk appetite, legal requirements, standards, and security strategy.
- Collect evidence about the current state.
- Identify and document gaps.
- Assess the risk and business impact of each gap.
- Prioritize gaps based on criticality, exposure, regulatory importance, dependencies, cost, and feasibility.
- Assign owners, timelines, resources, and measures of completion.

Exam point: do not automatically fix every gap in the same order. **Prioritize using risk and business impact.**

4. Control Objectives and Control Definition

A control objective states what a control is intended to achieve. Control definition translates the objective into specific requirements, procedures, responsibilities, and expected evidence.

- **Risk assessment:** identifies what can go wrong and the possible impact.
- **Control objective:** states the desired protection or outcome.
- **Control definition:** specifies what must be implemented and who is responsible.
- **Control implementation:** puts the control into operation.
- **Control monitoring:** checks whether the control continues to work.

A useful control definition should specify the scope, owner, frequency, inputs, activities, outputs, exceptions, evidence, escalation path, and success criteria.

5. Governance of Third-Party Relationships

Third-party governance ensures that business objectives and security requirements remain aligned throughout the relationship lifecycle. The organization must retain appropriate oversight even when services or systems are provided externally.

The screenshot identifies four governance areas:

- **Risk assessment:** address potential risks and possible impacts on operations, data security, and compliance obligations.
- **Security impact analysis:** assess the consequences of possible security failures and ensure adequate protection measures throughout the relationship.
- **Failure management:** recognize and manage potential failures through contractual provisions and operational oversight.
- **Engagement model:** establish a formalized working model between Information Security and the business group engaging third parties.

The engagement model should clarify who makes decisions, who approves exceptions, who owns the risk, who manages the vendor, how security participates in procurement, and how issues are escalated.

6. Third-Party Risk Management Lifecycle

The lifecycle shown in the screenshot contains five stages:

Stage	Purpose and key activities
1. Initial assessment	Evaluate suitability before establishing the relationship. Use RFI/RFP processes where vendors provide structured information about their services, capabilities, controls, and risks.

2. Onboarding	Perform due diligence before using the product or service. Understand risk levels and establish baseline security expectations, access requirements, data handling rules, and responsibilities.
3. Legal agreement	Negotiate services, service levels, quality, pricing, security, privacy, audit rights, incident notification, data ownership, continuity, subcontracting, and termination requirements.
4. Ongoing monitoring	Continuously assess the relationship, verify compliance with agreements, review performance, reassess risk, and monitor emerging threats or changes.
5. Termination	End the relationship formally. Remove access, return or securely destroy data, address records retention, recover assets, transition services, and confirm contractual obligations are fulfilled.

Important: third-party risk assessment is not a one-time procurement activity. It continues throughout the relationship because the provider, service, threat landscape, regulations, and business dependency may change.

7. Assessing Third-Party Risk

Third-party assessment often requires more effort than internal assessment because the security manager's view of the provider's information, processes, systems, and controls may be limited or obscured. Cooperation from external personnel may vary.

Organizations should evaluate providers both at the beginning of the relationship and periodically thereafter. Third-party risk should be incorporated into the organization's overall risk assessment process.

The screenshot identifies four important risk categories:

- **Financial risk:** financial stability, currency exchange exposure, cost-management practices, and the possibility of provider failure.
- **Operational risk:** operational effectiveness, service-delivery capabilities, resilience, staffing, dependencies, and legal/compliance issues.
- **Geopolitical risk:** political stability, regulatory environment, regional conflicts, sanctions, cross-border restrictions, and country exposure.
- **Security posture:** recent security breaches, security certifications, incident-response capabilities, vulnerability management, and security governance.

Additional due-diligence evidence may include independent audit reports, certifications, penetration-test summaries, business continuity and disaster recovery results, security questionnaires, incident history, architecture documentation, subcontractor information, and references.

8. Controls and Implementation Disconnection

The screenshot distinguishes between activities generally owned by the organization and activities generally performed by the provider:

Organization responsibility	Provider responsibility
Risk assessment	Control implementation
Control definition	Control monitoring

This division is a useful conceptual model, not a license for the organization to abandon oversight. The customer remains accountable for determining its risk, defining requirements, and verifying that the provider's implementation and monitoring satisfy those requirements.

The two control gaps highlighted in the screenshot are:

- **Controls among different outsourced functions:** ensure that controls remain coordinated when several vendors or outsourced services interact.
- **Protection of information on third-party platforms:** ensure that information stored, processed, or transmitted on provider platforms remains protected.

9. Managing Outsourcing Risks

The screenshot groups outsourcing-risk actions into security, risk management, and vendor viability.

Security controls:

- Specify required levels of protection in SLAs and contracts.
- Perform specific audits or obtain appropriate independent certifications.
- Analyze third-party auditor comments and exceptions.
- Review periodic compliance assessments.
- Define audit rights, evidence requirements, access restrictions, encryption, logging, vulnerability management, and security reporting.

Risk-management controls:

- Include response and recovery activities and testing.
- Implement an incident-response plan jointly with outsourcing entities.
- Define escalation, communication, decision rights, and regulatory-notification support.
- Ensure business continuity, disaster recovery, crisis management, and exit plans are tested.

Vendor-viability considerations:

- Assess financial stability and the ability to continue service delivery.
- Review dependency on key personnel, subcontractors, technology, and locations.
- Evaluate the provider's resilience and recovery capability.
- Define transition, data-return, data-destruction, and access-revocation requirements.
- Plan for provider failure, acquisition, insolvency, geopolitical disruption, or loss of a critical service.

10. Cloud Computing

Cloud computing provides on-demand access to shared computing resources such as servers, storage, networks, platforms, and applications. Cloud risk management requires clarity about responsibility, visibility, data location, configuration, identity, resilience, and provider dependency.

Cloud service models

Model	What the provider supplies	Customer focus
IaaS	Computing resources, storage, networking, and related infrastructure.	Operating systems, configurations, applications, identities, data, and workload security.
PaaS	Development environment, runtime, middleware, and platform services.	Application code, identities, data, configurations, and secure development practices.
SaaS	Complete applications delivered through the web or another service interface.	Identity, access, data governance, configuration, usage, compliance, and vendor oversight.

Cloud deployment models

- **Public cloud:** shared infrastructure operated for multiple customers or tenants.
- **Private cloud:** dedicated cloud infrastructure for one organization. It may be operated internally or by a third party.
- **Hybrid cloud:** combination of public and private cloud resources, usually connected for portability, integration, or workload placement.
- **Community cloud:** infrastructure shared by organizations with common concerns, such as mission, compliance, security, or policy requirements.

Cloud exam considerations:

- The cloud provider's responsibility does not eliminate the customer's accountability for its own risk.
- Use a documented shared-responsibility model.
- Assess provider security, availability, resilience, privacy, data location, subcontractors, and exit capability.
- Secure identities, privileged access, configurations, APIs, encryption keys, logs, backups, and network connectivity.
- Confirm that contractual commitments match the organization's risk appetite and regulatory obligations.

11. Release Management

Release management is the ITIL process that controls how application changes are deployed into production environments. It is a crucial final stage of the software development life cycle because it moves an approved change into the live environment.

Effective release management ensures that changes are implemented systematically, with minimal disruption to services while maintaining security integrity.

Types of releases or changes shown in the screenshot:

- **Incident and problem resolution:** bug fixes implemented in response to incidents where changing application software is the appropriate remedy.
- **Enhancements:** new functions created from customer requests or the long-range vision of software designers.
- **Subsystem patches and changes:** updates to lower layers that require testing similar to application changes, such as operating-system patches and database upgrades.

Release-management controls should include change authorization, risk assessment, segregation of duties, testing, rollback planning, version control, configuration management, deployment windows, communication, evidence, post-implementation review, and emergency-change procedures.

Exam point: a patch to an operating system or database is still a change that may affect application security, availability, integrity, and compatibility. It should not be treated as automatically harmless.

12. Resolution of Noncompliance Issues

Noncompliance may create risk to the enterprise. The organization should develop specific processes to deal with noncompliance in a timely and effective manner.

The screenshot identifies the following approach:

- Provide quick resolution for serious risk issues.
- Determine criticality and use a risk-based response.
- Develop and assign responsibility to address each noncompliance item.
- Perform regular follow-up to ensure that items are addressed.

Ways to identify noncompliance include:

- Normal monitoring

- Audit reports
- Security reviews
- Vulnerability scans
- Due diligence

A good remediation record should include the issue, requirement violated, affected asset or process, risk rating, root cause, owner, corrective action, target date, interim safeguards, evidence of completion, and validation of closure.

Do not confuse a documented exception with remediation. An exception is a formally accepted deviation, usually requiring an accountable risk owner, rationale, compensating controls, expiry or review date, and appropriate approval.

13. Continuous Improvement of the Information Security Program

Continuous improvement is the ongoing effort to increase the efficiency and effectiveness of information security processes and controls over time.

The screenshot presents a four-step cycle:

Step	Meaning
Assess	Evaluate the current state of information security controls and processes.
Plan	Develop strategies to address gaps and enhance effectiveness.
Implement	Execute improvements to processes and controls.
Monitor	Track performance and identify new opportunities for improvement.

The screenshot associates continuous improvement with ISO/IEC 27001, NIST SP 800-53 Rev. 5, and the NIST Cybersecurity Framework. In practice, improvement may be triggered by incidents, audit findings, new threats, control failures, business changes, technology changes, regulatory changes, or lessons learned.

14. High-Value CISM Decision Rules

- **Business alignment comes first:** security initiatives should support business objectives and risk appetite.
- **Risk before controls:** assess the risk and impact before selecting or prioritizing controls.
- **Ownership matters:** the organization cannot outsource accountability merely by outsourcing execution.
- **Criticality drives urgency:** serious or high-risk issues require faster action and escalation.
- **Third-party oversight is continuous:** initial due diligence is not enough.
- **Contracts are security instruments:** SLAs, audit rights, incident notification, data handling, resilience, and exit clauses matter.
- **Evidence beats assumption:** use audits, certifications, assessments, testing, monitoring, and documented results.
- **Exceptions must be governed:** document, approve, monitor, and review them.
- **Change is risk:** application releases, OS patches, database upgrades, and cloud configuration changes require controlled implementation.
- **Improve the program, not only individual controls:** use feedback and metrics to strengthen the overall system.

15. Quick Revision Checklist

- Can I explain the difference between current state, target state, and gap?

- Can I distinguish risk assessment, control definition, implementation, and monitoring?
- Can I recite the five stages of the third-party risk lifecycle in order?
- Can I explain why third-party risk assessment is harder than internal assessment?
- Can I identify financial, operational, geopolitical, and security-posture risks?
- Can I explain organization versus provider responsibilities?
- Can I compare IaaS, PaaS, and SaaS?
- Can I compare public, private, hybrid, and community clouds?
- Can I explain why cloud security follows a shared-responsibility model?
- Can I distinguish incident fixes, enhancements, and subsystem patches?
- Can I explain how noncompliance is identified, prioritized, assigned, remediated, and validated?
- Can I describe the Assess–Plan–Implement–Monitor improvement cycle?
- Can I identify what must be covered in a third-party contract?
- Can I explain why release management is a security concern?

Final Exam Reminder

When a CISM question presents several possible actions, select the option that best reflects the correct management sequence: understand the business objective, assess risk and impact, establish requirements and ownership, then implement, monitor, and improve. Escalate immediately when the situation is already severe, urgent, or materially threatens the enterprise; otherwise, use a documented risk-based process.